

Authentication Testing Methodologies:

Auth testing is the process of the probing and exploiting weaknesses in web app's identity verification mechanisms.

This involves various auth controls like login forms, passwd reset functionality, MFAs and account lockouts, to discover any vuln that could allow unauthorized access or account compromise.

Methodologies:

1. Testing for credentials Transported over an Encrypted Channel
2. Testing for Default Credentials
3. Testing for Weak Lock Out Mechanism
4. Testing for Bypassing Authentication Schema
5. Testing for Vulnerable Remember Password Function:
 - a. Lets a web app has forgot password functionality, if you enter an email again and lets just say its real or not real essentially you are performing a test, the web app will not tell you whether that email belongs to an account. So, there's no information that it's that being exposed so the attacker will not be able to tell that hey there is an account with this email that if this account is registered with us, we will send a password reset email to the email
6. Testing for Browser Cache Weaknesses
 - a. Ensuring sensitive infor is not stored insecurely in the browser cache, where attackers could retrieve it.
7. Testing for Weak Password Policy
 - a. Examines the app's password policy to determine if it enforces sufficient password complexity and expiration requirements.
8. Testing for Weak Authentication in Alternative Channels.
 - a. Like API's, mobile apps.